Department Shared Folders & Access Test

AccessGuard Health – Healthcare IAM Operations Simulation

Lab record: turning the RBAC design into folders that enforce it, with a working access test on the EHR share

Project Name	AccessGuard Health
Project Type	Healthcare IAM Operations Simulation – Home Lab
Organization	Horizon Valley Medical Center (HVMC) – fictional
Board Task	Build On-Prem Apps via Shared Folders (in progress); on-prem part of Assign Applications and Verify End-to-End Login
Document Version	1.0
Prepared By	Sabitha S Karanavar
Lab Date	November 2, 2026

1. Purpose

The RBAC matrix and the security groups describe **who should have access to what**. This document records how that design was made real on the domain controller: each hospital application is represented by a **shared folder**, and only the departments the matrix names can open it. The EHR (electronic health record) folder was built first and tested end to end: a Doctors user is allowed in, and a Finance user is refused.

Everything here is a fictional training environment: no real patient data or real credentials are used.

2. Design

One folder per application on **hvmc-dc01**, under `/srv/shares`. Access follows the RBAC matrix. A department group gets read/write (rwx) or read-only (r-x); everyone else gets nothing.

Share	Read/write	Read-only
EHR	Doctors, Nursing	Pharmacy, Lab, Reception
PharmacySystem	Pharmacy	Doctors, Nursing
LIS	Lab	Doctors, Nursing
Payroll	HR, Finance	–
HRPortal	HR	Finance
FinanceERP	Finance	–
ITAdmin	IT (admin)	Contractors (limited)

Share	Read/write	Read-only
Scheduling	IT (admin), Reception	–
SecurityPortal	Security (admin)	–
VPN	–	IT, Contractors

Access is enforced in two layers, which is the on-premises equivalent of Windows NTFS permissions plus AD groups: **POSIX ACLs** on the Linux folder, and a **Samba share** that lists which groups may connect.

3. Step 1 – Let the Server See Domain Groups

Folder permissions need the server to turn a group name such as `HVMC\sg-doctors-ehr-rw` into a group ID. The lookup was tested first and returned nothing.

```
getent group "HVMC\SG-Doctors-EHR-RW"
grep -E "^(passwd|group)" /etc/nsswitch.conf
```

The name-service file listed only `files systemd`, with no **winbind**, so Linux never asked Samba about domain groups. The winbind service was installed, but the piece that connects it to name lookup, `libnss-winbind`, was missing.

```
ubuntu@hvmc-dc01:~$ getent group "HVMC\SG-Doctors-EHR-RW"
ubuntu@hvmc-dc01:~$ grep -E "^(passwd|group)" /etc/nsswitch.conf
passwd:         files systemd
group:          files systemd
ubuntu@hvmc-dc01:~$
```

Figure 1: Before: the group lookup is empty and nsswitch has no winbind

```
sudo apt install -y libnss-winbind
```

The installer added winbind to `/etc/nsswitch.conf` by itself. The lookup was then repeated:

```
No VM guests are running outdated hypervisor (qemu) binaries on this host.
ubuntu@hvmc-dc01:~$ getent group "HVMC\SG-Doctors-EHR-RW"
HVMC\sg-doctors-ehr-rw:x:3000020:
ubuntu@hvmc-dc01:~$
```

Figure 2: After: the group resolves to HVMC\sg-doctors-ehr-rw with group ID 3000020

4. Step 2 – Create the Folder and Set Permissions

The EHR folder was created and locked down so that the owner and group have full access and others have none (`770`). Then an ACL entry was added for each department group that works with the EHR, and the result was checked.

```
sudo mkdir -p /srv/shares/EHR
sudo chmod 770 /srv/shares/EHR
sudo setfacl -m "g:HVMC\sg-doctors-ehr-rw:rwx" /srv/shares/EHR
sudo setfacl -m "g:HVMC\sg-nursing-ehr-rw:rwx" /srv/shares/EHR
getfacl /srv/shares/EHR
```

```
ubuntu@hvmc-dc01:~$ sudo mkdir -p /srv/shares/EHR
ubuntu@hvmc-dc01:~$ sudo chmod 770 /srv/shares/EHR
ubuntu@hvmc-dc01:~$ sudo setfacl -m "g:HVMC\sg-doctors-ehr-rw:rwx" /srv/shares/EHR
ubuntu@hvmc-dc01:~$ sudo setfacl -m "g:HVMC\sg-nursing-ehr-rw:rwx" /srv/shares/EHR
ubuntu@hvmc-dc01:~$ getfacl /srv/shares/EHR
getfacl: Removing leading '/' from absolute path names
# file: srv/shares/EHR
# owner: root
# group: root
user::rwx
group::rwx
group:HVMC\\sg-doctors-ehr-rw:rwx
group:HVMC\\sg-nursing-ehr-rw:rwx
mask::rwx
other::---
```

Figure 3: Folder ACL: Doctors and Nursing have rwx, everyone else has none (other::---)

5. Step 3 – Publish the Folder as a Samba Share

The share was added to the end of Samba's config file, naming the folder and the two groups allowed to connect. The block was typed in by hand using a here-document, which appends it without opening an editor.

```
sudo tee -a /etc/samba/smb.conf <<'EOF'

[EHR]
        path = /srv/shares/EHR
        read only = no
        valid users = "@HVMC\sg-doctors-ehr-rw", "@HVMC\sg-nursing-ehr-rw"
EOF
```

```
ubuntu@hvmc-dc01:~$ sudo tee -a /etc/samba/smb.conf <<'EOF'
>
[EHR]
        path = /srv/shares/EHR
        read only = no
        valid users = "@HVMC\sg-doctors-ehr-rw", "@HVMC\sg-nursing-ehr-rw"
EOF

[EHR]
        path = /srv/shares/EHR
        read only = no
        valid users = "@HVMC\sg-doctors-ehr-rw", "@HVMC\sg-nursing-ehr-rw"
ubuntu@hvmc-dc01:~$
```

Figure 4: The [EHR] share added after [sysvol] and [netlogon]

Samba then checked the file, and the running services were told to re-read it, so no restart was needed.

```
sudo testparm -s
sudo smbcontrol all reload-config
```

```
Load smb config files from /etc/samba/smb.conf
Loaded services file OK.

[sysvol]
        path = /var/lib/samba/sysvol
        read only = No


[netlogon]
        path = /var/lib/samba/sysvol/hvmc.lan/scripts
        read only = No


[EHR]
        path = /srv/shares/EHR
        read only = No
        valid users = @HVMC\sg-doctors-ehr-rw @HVMC\sg-nursing-ehr-rw
ubuntu@hvmc-dc01:~$
```

Figure 5: Samba accepts the config ("Loaded services file OK") and lists [EHR]

6. Step 4 – Test the Access from the Client

From **hvmc-client01**, the command-line file-sharing tool `smbclient` was installed and used to connect to the share as two different users.

```
sudo apt install -y smbclient
smbclient //hvmc-dc01.hvmc.lan/EHR -U 'HVMC\sarah.chen'
smbclient //hvmc-dc01.hvmc.lan/EHR -U 'HVMC\brian.adeyemi'
```

User	Group	Expected	Result
sarah.chen (Doctors)	SG-Doctors-EHR-RW	Allowed	Connected and listed the folder (smb: \> prompt)
brian.adeyemi (Finance)	SG-Finance-Payroll-RW	Refused	NT_STATUS_ACCESS_DENIED

```
ubuntu@hvmc-client01:~$ smbclient //hvmc-dc01.hvmc.lan/EHR -U 'HVMC\sarah.chen'
Password for [HVMC\sarah.chen]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Mon Nov  2 08:46:36 2026
  ..                                  D        0  Mon Nov  2 08:46:36 2026

                10218772 blocks of size 1024. 4799988 blocks available
smb: \> exit
ubuntu@hvmc-client01:~$ smbclient //hvmc-dc01.hvmc.lan/EHR -U 'HVMC\brian.adeyemi'
Password for [HVMC\brian.adeyemi]:
tree connect failed: NT_STATUS_ACCESS_DENIED
ubuntu@hvmc-client01:~$
```

Figure 6: Sarah (Doctors) is let in; Brian (Finance) is refused with ACCESS_DENIED

This is the working access chain for one role: **domain sign-in → group membership → access to the resource**. Brian signed in successfully, so his password was accepted; the refusal comes only from the

group check, which is exactly what role-based access control should do.

7. Troubleshooting Log

Issue	Cause	Resolution
Group lookup printed nothing	nsswitch.conf had no winbind entry; libnss-winbind was not installed	Installed libnss-winbind, which added winbind automatically
Unsure if two setfacl commands were a mistake	One command was needed per group (Doctors and Nursing)	Confirmed by getfacl; repeating a setfacl command is harmless
getfacl shows HVMC\\sg-doctors-ehr-rw (double backslash)	getfacl escapes the backslash when printing	No change needed

8. Security Considerations

- All names, departments and users are **fictional**; no real patient or employee data is used.
- **Default deny:** the folder gives "others" no access (`770`); only named groups get in.
- **Least privilege:** read-only groups (Pharmacy, Lab, Reception on EHR) cannot change records.
- **Two layers:** the Samba share lists allowed groups and the folder ACL enforces them, so a mistake in one layer does not open the folder.
- In production, shared folders live on a separate file server, not on a domain controller. The domain controller is used here for lab simplicity.
- Passwords entered during the test are practice-only credentials; none appear in the screenshots.

9. Key Outcomes

- Fixed a real gap: the server could not resolve domain groups until libnss-winbind was installed.
- Built the first of ten department shares (EHR) with group-based permissions from the RBAC matrix.
- Proved the control works in both directions: a Doctors user is allowed and a Finance user is refused.

10. Board Status

Board task	Status
Build on-prem apps via shared folders	In progress – 1 of 10 shares built; a script for the other nine is ready
Assign applications and verify end-to-end login (on-prem part)	Access chain proven on the EHR share; Entra part is documented separately

11. Next Steps

- Run the build script on the domain controller to create the other nine shares and add the read-only groups to EHR.
- Test that sarah.chen can open EHR but is refused on Payroll.
- Capture one screenshot per share and the full share list for the portfolio.
- Mark the shared-folder task complete on the Monday board.

12. Deliverables

- Department Shared Folders & Access Test: Lab Documentation for GitHub Portfolio (this document).
- Screenshots: group lookup before and after, folder ACL, Samba share, config check and the allowed/denied test.
- build_shares.sh: script that builds all ten shares from the RBAC matrix.